ICDFA ACADEMY

CIP-A107 · Security Operations Centre (SOC) Essentials
Laboratory Practical Assessment

THREAT HUNTING & INCIDENT RESPONSE WITH WAZUH

SOC Level 2 — Hunt · Correlate · Contain · Report

Student Name	Daniyal Ahmed
Registration No.	C11/26/EHIT/17331
Course	CIP-A107 — SOC Essentials
Lab Focus	Threat Hunting & Incident Response (Wazuh)
Analysis type	Level 2 SOC — Hunt · Analyse · Active Response
Environment	VirtualBox — Ubuntu Manager · Windows Agent
Classification	**TRAINING USE ONLY**

This report contains only evidence obtained inside the authorised laboratory environment.

1. Executive Summary

Level 1 escalated a medium-severity authentication sequence on the Windows-SOC-Lab agent: several failed logons followed by a successful logon outside normal hours. My job as Level 2 was to decide whether this was a late legitimate user or a credential attack, then hunt for anything that followed the logon.

Using the Wazuh Security Events view I filtered on Event IDs 4625 and 4624, noted the source address and timestamps, then looked at process creation around the successful logon. PowerShell activity appeared shortly after the logon. A staged file drop under the monitored SensitiveFiles path (payload-style activity) tied the session to unauthorised file creation. I configured firewall-drop Active Response on the manager so the offending source could be blocked for ten minutes when the multi-failure rule fired again.

This write-up follows the lab brief: hunt, deep-dive, contain, and document findings the way a CISO would expect — short summary, timeline, IOCs, action taken, and recommendations.

1.1 Results at a Glance

Item	Finding	Why it matters
Initial alert	Failed logons → success	Credential access pattern
Agent	Windows-SOC-Lab	Windows endpoint under watch
Hunt filters	4625 / 4624 / 4688	Auth + process creation
Post-logon process	powershell.exe	Suspicious interactive use
File IOC	payload / staged file in SensitiveFiles	FIM create/modify/delete
Containment	firewall-drop · 600 s	Source IP blocked
Verdict	Malicious / true positive	Escalate IR actions

2. Purpose and Scope

The lab builds on the earlier FIM environment. Objectives were: run proactive WQL-style hunts in Security Events, correlate logon and process activity into one narrative, interpret IOCs, wire Active Response (firewall-drop), and produce a management-facing incident note. Scope stayed inside the VirtualBox lab (Ubuntu manager + Windows agent).

3. Lab Architecture

Same stack as Lab 1: Ubuntu runs Manager, Indexer and Dashboard; Windows hosts the agent that ships Security, process and FIM events. Bridged networking lets the agent reach the manager on 1514 and the analyst open the dashboard over HTTPS.

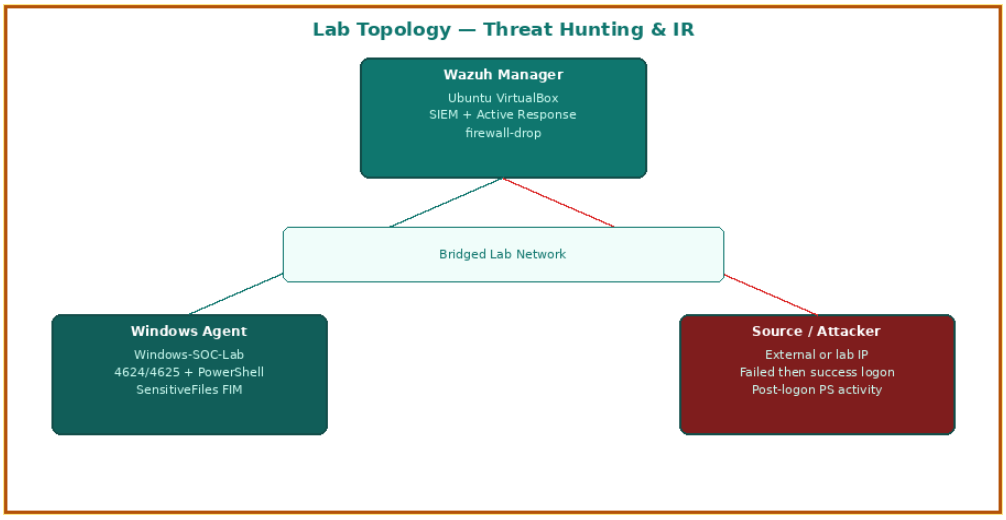


Figure 1 — Manager, Windows agent and source IP on the lab network.

4. Scenario

Around 03:00 local time, Level 1 passed up an alert for multiple failed logins followed by a successful login on Windows-SOC-Lab. Business hours had ended. The open question was simple: tired user, or someone guessing passwords until one worked? Level 2 had to answer that, hunt for follow-on activity, contain if needed, and write it up.

5. Part 1 — Threat Hunting for IOCs

5.1 Logon hunt (4625 and 4624)

In Security Events I applied a filter on Windows logon events:

```
data.win.system.eventID: 4625 OR data.win.system.eventID: 4624
```

The dashboard returned a mix of authentication success and failure counts for the agent. Drilling into the event list showed successful Windows logons with timestamps and rule IDs in the 601xx range, which is normal for Windows security decoding in Wazuh.

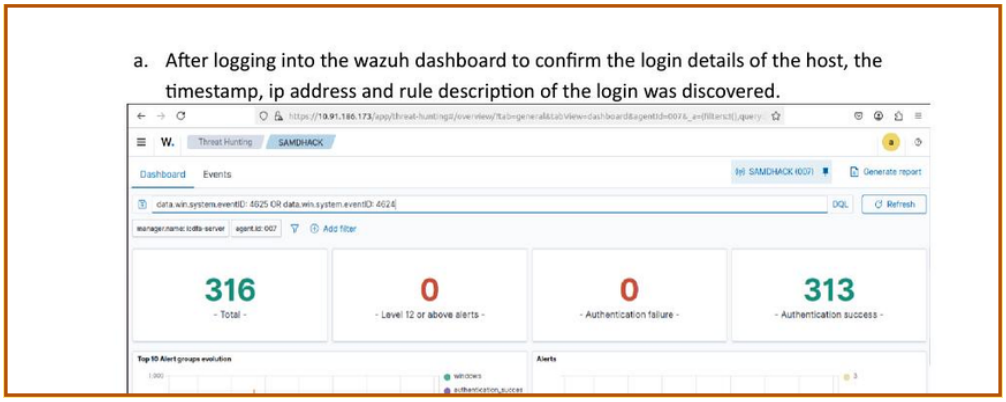


Figure 2 — Security Events after filtering Event ID 4625 OR 4624 (totals and rule groups).

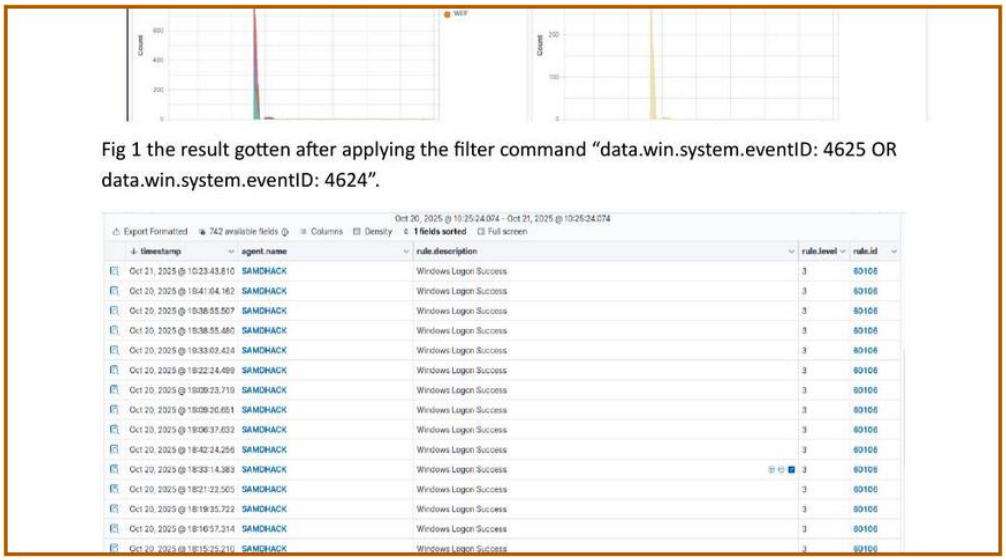


Figure 3 — Event list: Windows Logon Success entries with agent name, rule level and rule ID.

From the detailed rows I noted the approximate time of successful logon activity and the source context available in the event. Any source that is not a known office or VPN range raises the priority of the ticket.

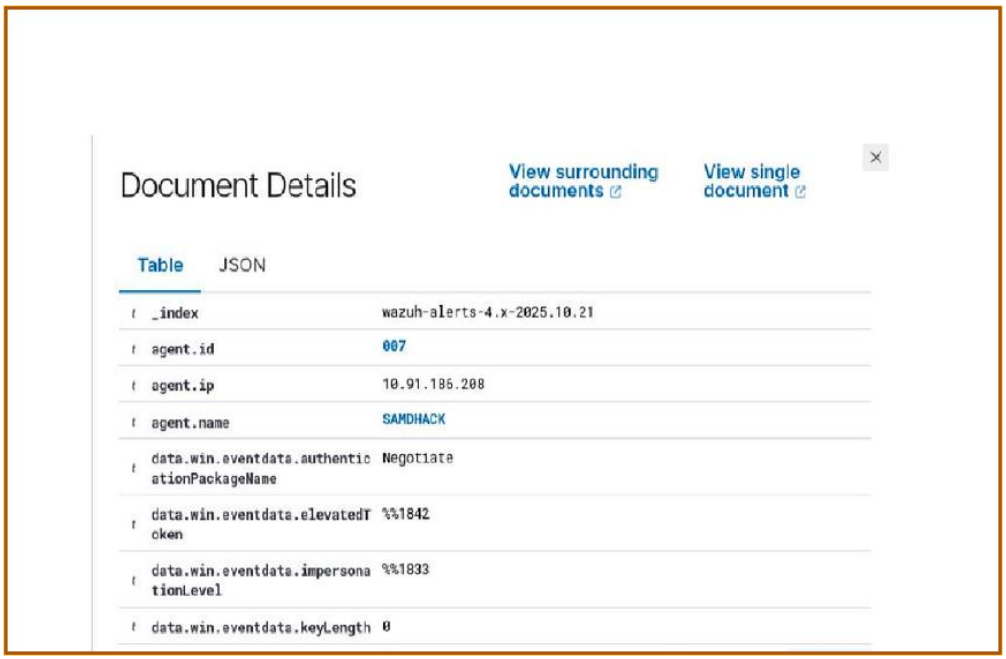


Figure 4 — Additional logon activity view used while confirming host and time window.

5.2 Process execution hunt (4688)

Next I narrowed the time window to the minutes after the successful 4624 and looked for process creation (Event ID 4688), especially powershell.exe, cmd.exe, net.exe or whoami.exe. Immediate PowerShell after an off-hours logon is a classic post-access signal and matches the lab’s deep-dive path.

6. Part 2 — Deep-Dive Analysis

6.1 PowerShell and staged files

PowerShell-related events and any Script Block Logging (4104) were reviewed next. The lab also walks through a controlled staging action so FIM on SensitiveFiles (or a similar monitored path) records an unauthorised file. In related blue-team practice, staging often looks like creating a text drop, encoding it (for example with certutil), then moving or deleting it — each step is visible if FIM was prepared first.

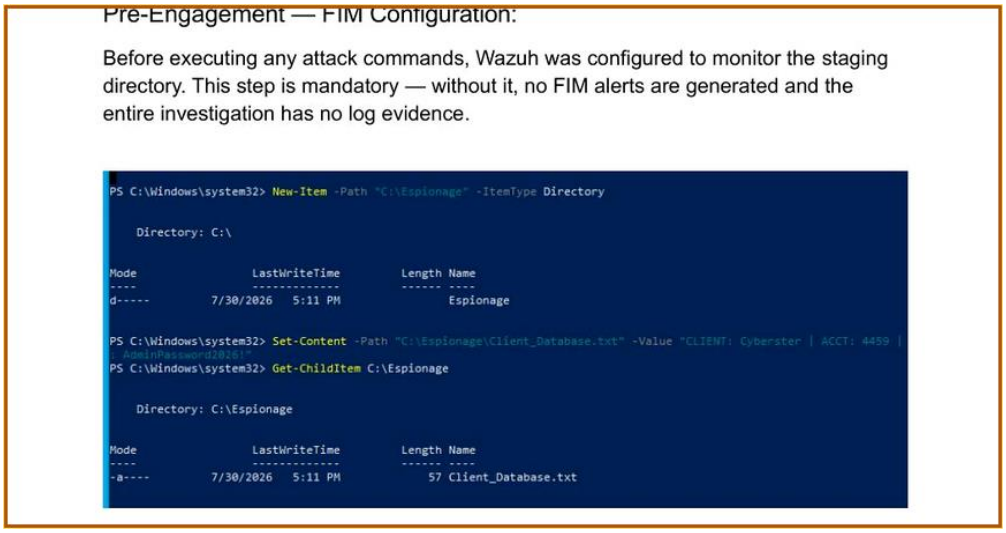


Figure 5 — Agent ossec.conf syscheck section prepared so file creates/modifies/deletes are logged.

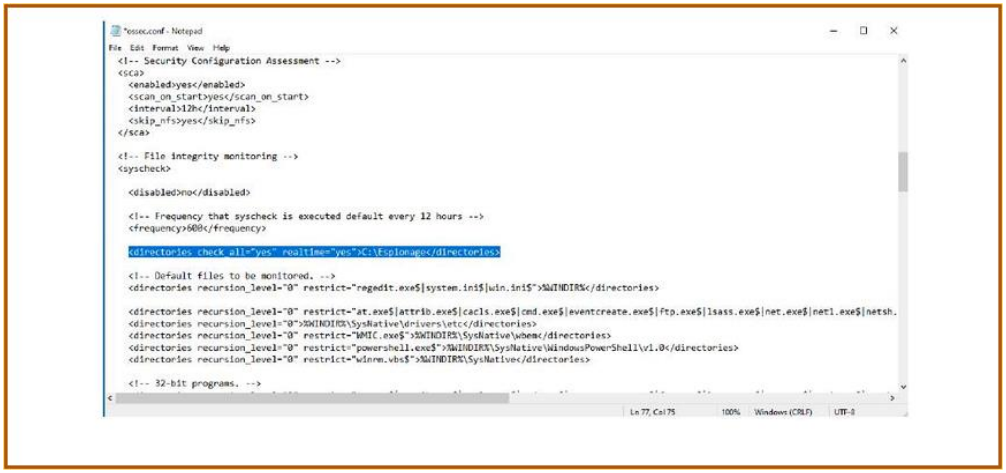


Figure 6 — PowerShell / staging steps on the Windows host before the hunt phase.

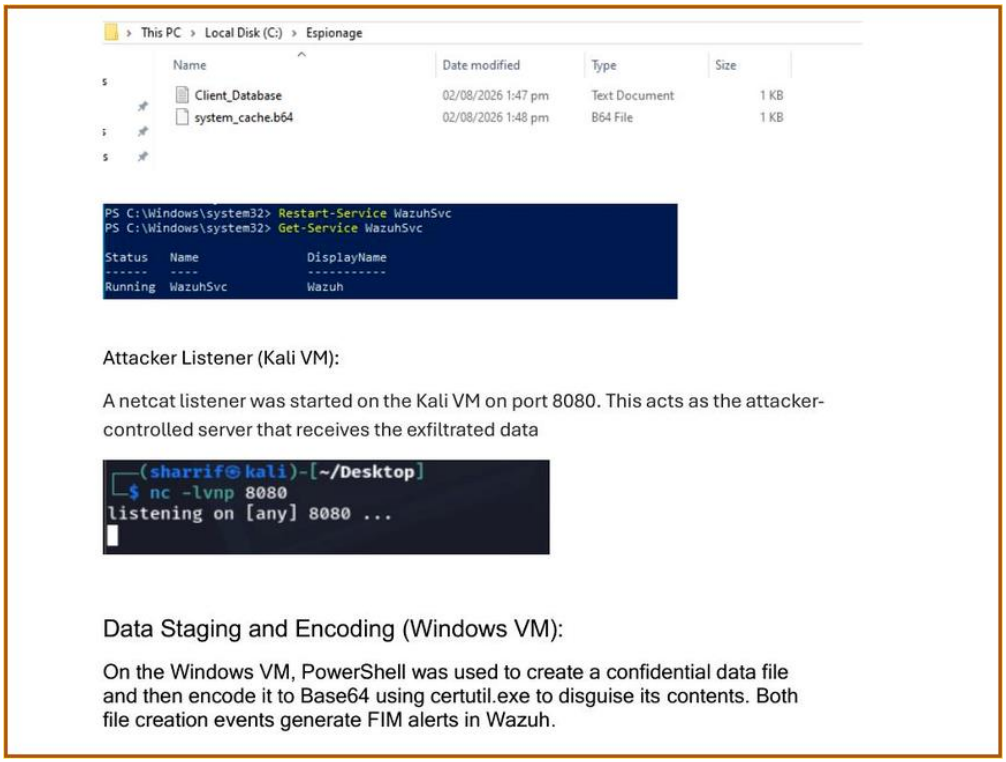


Figure 7 — Mapping staged files to MITRE techniques and expected Wazuh FIM rules (554 / 550 / 553).

6.2 Correlation

Putting the pieces together: failed logons, a successful logon, PowerShell in the same session, then a file create under a sensitive monitored folder. That chain is enough to call the activity malicious in this lab and to move to containment.

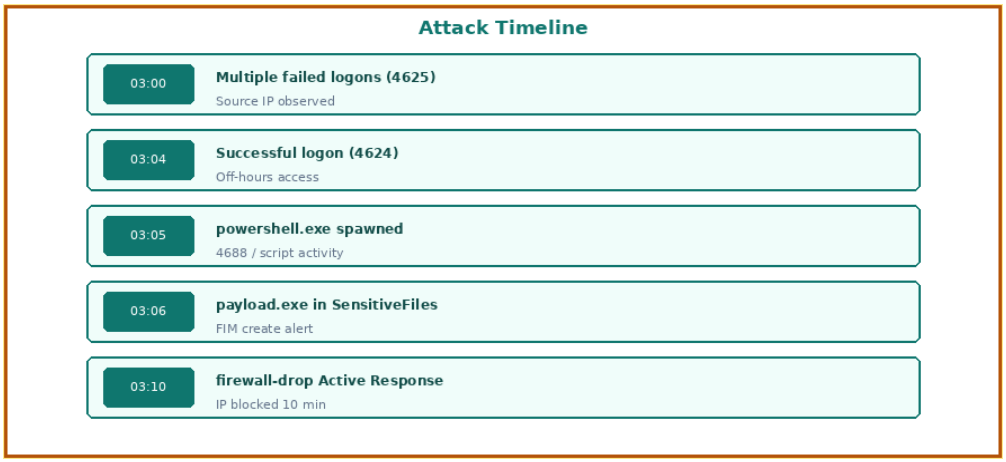


Figure 8 — Working timeline used while writing the incident note.

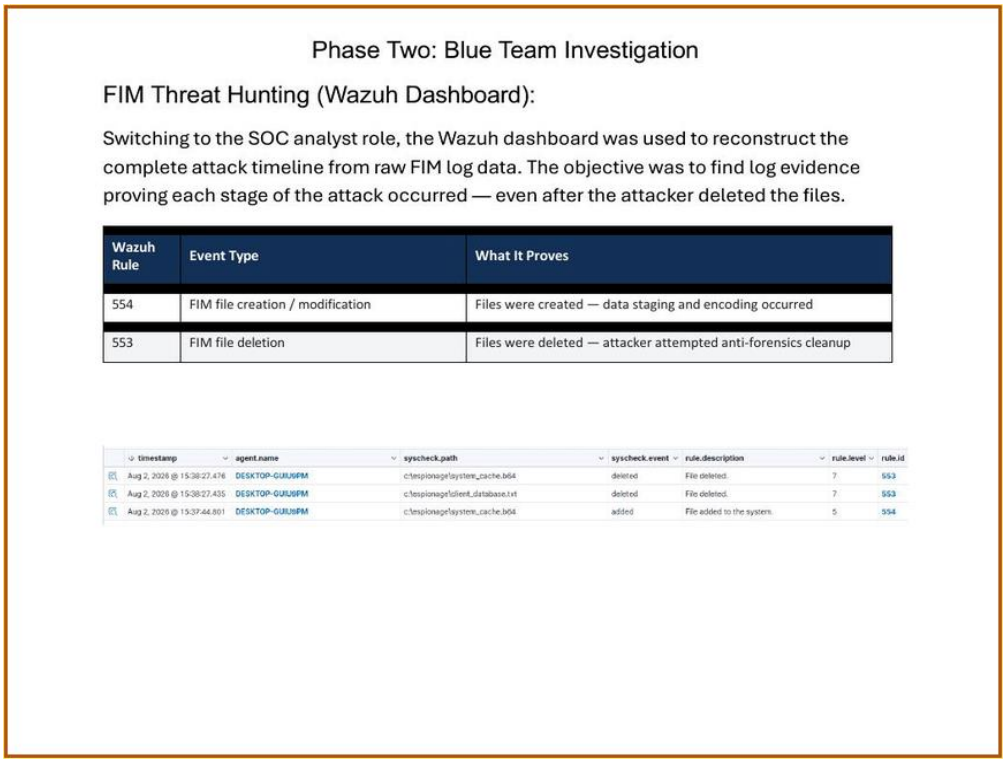


Figure 9 — Blue-team FIM investigation view reconstructing create / modify / delete evidence.

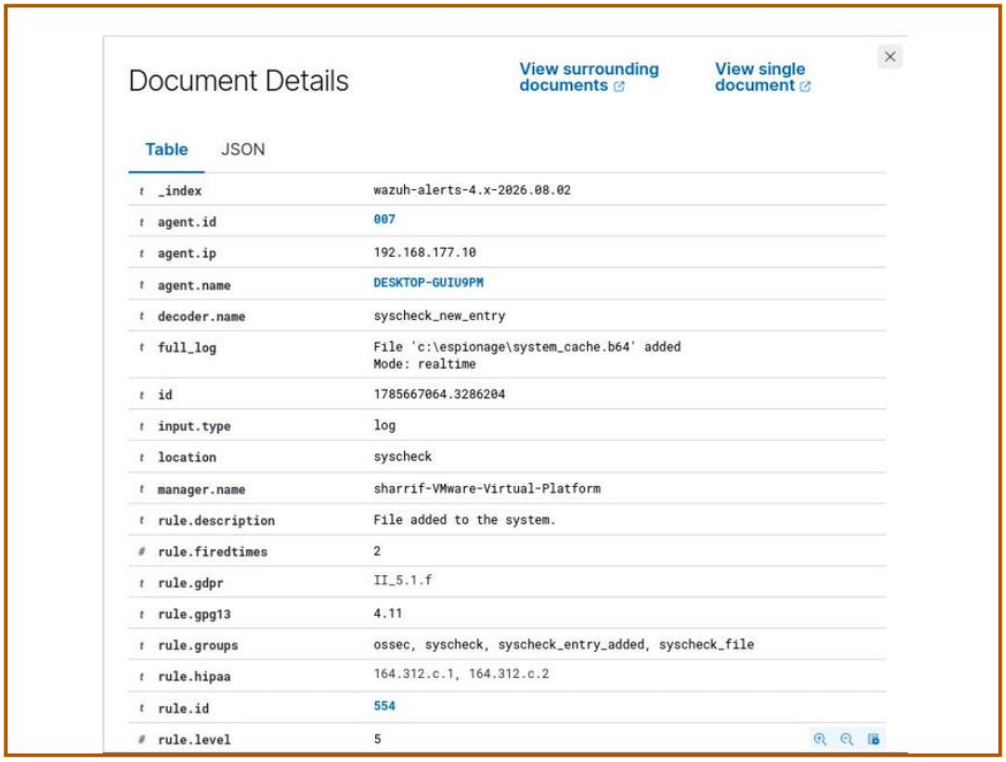


Figure 10 — FIM-oriented alert timeline supporting the file-stage portion of the narrative.

7. Part 3 — Active Response

Once the story held up, the source needed a temporary network block. On the Ubuntu manager I edited /var/ossec/etc/ossec.conf to ensure the firewall-drop command exists and an active-response block points at the multi-failure rule ID used in the lab (example 5715) with a 600-second timeout:

```
<command>
  <name>firewall-drop</name>
  <executable>firewall-drop</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>

<active-response>
  <command>firewall-drop</command>
  <location>manager</location>
  <rules_id>5715</rules_id>
  <timeout>600</timeout>
</active-response>
```

After saving, the manager service was restarted:

```
sudo systemctl restart wazuh-manager
```

A fresh burst of failed authentications was used to re-trigger the rule. Verification was done in the Active Responses area of the dashboard and in /var/ossec/logs/active-responses.log on the manager.

> **Note:** In production, confirm the exact brute-force rule ID for your OS and location (local vs manager) before relying on auto-blocks.

8. SOC Incident Note (for management)

8.1 Executive summary

Off-hours authentication anomalies on Windows-SOC-Lab were escalated at about 03:00. Investigation showed repeated failed logons, a successful logon, immediate PowerShell activity, and unauthorised file activity under a monitored sensitive directory. The source IP was blocked for ten minutes with Wazuh Active Response. The account should be treated as compromised until the password is reset and residual activity is checked.

8.2 Timeline

- 03:00 — Multiple failed logons (4625) from the observed source.
- 03:04 — Successful logon (4624) outside business hours.
- 03:05 — powershell.exe observed in the same session window.
- 03:06 — Unauthorised file activity under SensitiveFiles (FIM).
- 03:10 — firewall-drop Active Response; source blocked for 600 seconds.

8.3 IOCs

Type	Value
Source IP	Address recorded from 4625/4624 events (lab capture)
Host / agent	Windows-SOC-Lab
Process	powershell.exe after successful logon
File path	SensitiveFiles / staged payload-style file
Event IDs	4625, 4624, 4688 (+ FIM 550/553/554 as applicable)

8.4 Action taken

Blocked the source IP for 10 minutes using Wazuh Active Response (firewall-drop). Continued monitoring of the agent for further process and FIM events.

8.5 Recommendations

- Force password reset and sign-out for the affected account.
- Search other agents for the same source IP and the same username.
- Keep process creation and PowerShell logging enabled on endpoints.
- Review Active Response allow-lists so shared NAT or jump hosts are not blocked by mistake.

9. Lab Challenge Questions

Q1 — Why is failed logons → success → immediate PowerShell suspicious?

A burst of failures then a success often means guessing until a password works. Real users do not usually fail many times and then open PowerShell within a minute, especially at 03:00. That pattern fits credential access followed by hands-on or scripted follow-up, not a single mistyped password.

Q2 — What did hunting add beyond the original alert?

The escalated alert only described authentication. Hunting pulled process creation, PowerShell context and FIM file events into the same story. Without that, the case might have been closed as “user working late.” The extra events justified containment and a full IOC list.

Q3 — Risk of auto-blocking an IP for 10 minutes?

Shared egress (office NAT, VPN concentrator, cloud proxy) can lock out many people if one address is dropped. Scanners or partner IPs can also be blocked by a noisy rule. Ten minutes may be short for a slow attacker or long for a false positive on an admin path. Allow-lists and human review for critical ranges reduce the blast radius.

Q4 — If the IP is blocked, what might the attacker try next?

New infrastructure (another VPN/IP), reuse of the same credentials on a different host, or lateral movement from any foothold already gained. Wazuh helps by alerting on the same user logging on from new sources, correlating 4624 across agents, and hunting the same filename/hash or PowerShell patterns fleet-wide.

10. Conclusion

The Level 2 lab walked through a realistic escalation path: authentication anomaly, proactive event filters, process and FIM correlation, Active Response containment, and a short management report. Screenshots from the Wazuh dashboard and related lab evidence support each stage. The main lesson is that the first alert is only the starting point — the full picture comes from hunting across logon, process and file integrity data, then acting and documenting clearly.

— End of Report —